OT機器情報と公開脆弱性情報の対応付け可能性に関する調査と実機評価

黒木 琴海[1,a)]　久保 佑介[1,2]　田中 洋平[1]　前田 浩明[1]　加島 伸悟[1]

概要：OT（Operational Technology）環境の脆弱性管理には，機器の製品・版情報と公開脆弱性情報の対応付けが必要だが，両者の記述粒度差が自動化を妨げる．本研究では，6 種の OT プロトコルと 6 社の公開状況を調査し，3 ベンダ 5 台・7 コンポーネントを，調査日時点の CSAF 文書 4,123 件と大規模言語モデルを用いない決定的規則で照合した．公開情報上，6 プロトコル中 5 プロトコルでモデルまたは製品コードの取得経路を確認した一方，ベンダ自身の CSAF は 6 社中 2 社であった．CVE・製品条件単位の 70 判定では，5 件を脆弱性該当，43 件を非該当と確定し，未確定 22 件は機器側 11 件と公開情報側 11 件に分かれた．主因は版数の多義性，版体系の不一致，製品記述の粒度差であり，自動対応付けには安定した製品固有キー，一意な版情報，コンポーネント単位の管理が必要である．

キーワード：OT セキュリティ，機器識別，脆弱性管理，産業用プロトコル

Feasibility of Mapping OT Device Information to Publicly Available Vulnerability Information: A Survey and Empirical Evaluation

Kotomi Kuroki[1,a)]　Yusuke Kubo[1,2]　Yohei Tanaka[1]　Hiroaki Maeda[1]　Shingo Kashima[1]

Abstract: OT (Operational Technology) vulnerability management requires mapping device product and version information to affected products and version ranges in public advisories, but differences in granularity hinder automation. We surveyed six OT protocols and six vendors and evaluated five devices from three vendors (seven components) against 4,123 CSAF documents collected at the time of the survey, using deterministic rules without large language models. Public documentation provided a path to a model name or product code for five of the six protocols, whereas vendor-operated CSAF feeds were found for only two of the six vendors. Of 70 CVE–product-condition decisions, five were conclusively classified as affected and 43 as not affected; the remaining 22 were split evenly between device-side and public-information-side causes. The main obstacles were ambiguous version notation, incompatible version schemes, and differences in product-description granularity. These findings indicate that automation requires stable product-specific keys, unambiguous version semantics, and component-level asset management.

Keywords: OT Security, Device Identification, Vulnerability Management, Industrial Communication Protocols

1. はじめに

OT（Operational Technology）環境の脆弱性管理では，稼働する資産の製品情報と版情報を把握し，公開脆弱性情報の影響製品・影響版条件と対応付ける作業が必要である．NIST および CISA のガイドラインも，セキュリティ対策の前提として OT 資産の把握を位置付けている [1], [2]．IT 資産においては，CPE 等の共通識別子を介して CVE と機械的に照合する方法が確立している．

しかし，OT 環境では同じ手順がそのまま成立しない．

[1] NTT ドコモビジネス株式会社
NTT DOCOMO BUSINESS, Inc.
[2] 早稲田大学
Waseda University
[a)] kotomi.kuroki@ntt.com

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

第 1 に，型式表記がベンダごとに異なり，共通識別子へ一意に写像できるとは限らない．第 2 に，CPU や通信ユニット等の複数コンポーネントが同一 IP アドレス上に存在するため，応答が示す対象と脆弱性の対象が一致しない場合がある．第 3 に，プロトコルの識別応答から得られる版情報が，脆弱性情報に記載されるファームウェア版と同一の版体系に基づくとは限らない．すなわち，識別子，対象単位，版体系のいずれにも不一致が生じ得る．

したがって，機器からモデル名や版数らしき値を取得できたとしても，それだけで脆弱性への該当を確定できるとは限らない．さらに，対応付けが確定しなかった場合に，その原因が機器側の識別情報にあるのか，公開脆弱性情報の記述にあるのか，照合方式にあるのかを切り分けられなければ，改善すべき対象を特定できない．

公開仕様上は識別情報を取得可能でも実機が応答しない場合や，取得値に対応する勧告が機械可読でない場合がある．そこで本研究では，公開情報調査と実機評価を組み合わせ，以下の Research Questions（RQs）を検討する．

- **RQ1**：対象とした OT プロトコルおよびベンダについて，公開情報から機器識別と脆弱性対応付けに必要な経路をどこまで確認できるか．
- **RQ2**：実機から得た識別情報を用いて，公開脆弱性情報との対応付けをどの判定レベルまで自動化できるか．
- **RQ3**：確定的な対応付けを妨げる要因は，機器側，公開情報側，照合方式側のどこにあるか．

本論文の貢献は次の 3 点である．

(1) 6 種の OT プロトコルについて，公開情報から確認できる識別要求と取得属性を整理し，プロトコル仕様上到達可能な識別粒度の上限と，その限界がどこにあるかを示した．

(2) 3 ベンダ 5 台・7 コンポーネントの実機と 4,123 件の CSAF 文書を用い，製品識別から CVE 単位の版条件判定までを段階的に評価することで，決定的規則のみで自動化できる範囲と，人手判断を要する範囲を分離して提示した．

(3) 確定的な脆弱性該当判定に至らなかった 22 件を機器側・公開情報側・方式側へ分解し，対応付けの障害が識別属性の欠落ではなく，版数の多義性，版体系の不一致，および製品記述の粒度差にあることを示した．これは，機器ベンダと脆弱性情報公開側のそれぞれが何を追加公開すべきかという具体的な要件につながる．

2. 背景と関連研究

2.1 OT 機器の識別

OT 資産の把握方法には，通信を観測するパッシブ方式，ポート・サービス走査，および産業用プロトコルの識別要求を送るアクティブ方式がある．既存の資産発見ツールに関する体系的レビューは，各方式の走査深度や機能を整理している [3]．Nmap 等にも OT 向け識別スクリプトが実装されている [4] が，取得した属性を公開脆弱性情報へ対応付ける処理は主眼ではない．本研究の目的に照らして重要なのは，各方式が取得できる属性の種類と粒度である．

公開脆弱性情報の影響製品・影響版条件と対応付けるには，最低限，製品固有キーに相当する型式情報と，版条件と比較可能な版情報が必要である．パッシブ方式は稼働中の通信を観測するため機器へ負荷を与えないが，取得できる属性は観測期間中に実際に流れたフレームに依存する．制御用の周期通信では型式や版数が搬送されないことが多く，これらの属性が観測されるかは通信内容に左右される．ポート・サービス走査は開放ポートとサービス種別を示すが，産業用コントローラ（PLC，PAC およびこれらに相当するベンダ固有呼称の製品）の型式や版数の粒度には到達しない．一方，アクティブ方式は産業用プロトコルの識別要求を明示的に送信するため，機器が当該要求へ応答する限り，型式および版に相当する属性を能動的に取得できる．したがって本研究では，型式・版情報の取得可能性の上限を評価する目的から，アクティブ方式を前提とする．本研究は方式間の優劣を比較するものではなく，アクティブ方式で到達可能な識別粒度が公開脆弱性情報の記述粒度と接続できるかを対象とする．

アクティブ方式による識別要求は，読み取り目的であっても無影響とは限らない．複数のスキャナを実機へ適用した既存評価では，復旧に再起動を要した事例が報告されている [5]．本研究では，公開資料から状態変更を意図しないと確認できる固定要求だけを対象とし，書込み，RUN/STOP，リセット，設定変更およびプログラム転送を対象外とする．ただし，本評価は操業影響を定量測定していないため，安全性を実証するものではない．

2.2 公開脆弱性情報と CSAF

CSAF 2.0 は，`product_tree` 内の製品エントリに付与した `product_id` を，CVE ごとの `product_status`（`known_affected` 等）から参照することで，製品と脆弱性の関係を機械可読に表現する [6]．ただし，`product_id` は文書内の参照用であり，機器の識別子とは直接一致しない．CPE，型番，SKU 等も記述できるが必須ではなく，対応付けの実効性は発行者の記述粒度に依存する．CISA は OT 向けを含むアドバイザリを CSAF 形式で公開している [7]．一方，CPE と CVE の単純な版一致は偽陽性を生じ得ることが指摘されており [8]，製品対応付けの根拠と版条件の評価を分けて扱う必要がある．

以上のように，CSAF は対応付けの機械的な基盤を与えるが，その実効性は，誰がどの粒度で情報を公開するかに依存する．そこで本研究では，「ベンダ自身が CSAF を公開していること」と「調整機関がベンダ情報を CSAF 化していること」を区別する．また，公開情報が見つからない

© 2026 Information Processing Society of Japan

場合を「脆弱性なし」と解釈しない．

2.3 本研究の位置付け

既存の資産発見研究は，ツールの走査深度や取得可能属性を比較するが [3]，取得した属性がアドバイザリの製品・版条件と対応するかまでは評価していない．一方，CPE／CVE 照合の研究は公開情報側の版一致に伴う偽陽性を扱うが [8]，OT プロトコルから取得した実機情報を入力としていない．本研究は，実機から取得した OT 固有の型式・版情報を公開 CSAF へ接続し，取得段階と対応付け段階を分離して評価するとともに，確定できない原因を機器側・公開情報側・照合方式側へ分解する点で異なる．

3. 調査・評価方法

本章では，公開情報調査および実機評価の方法を示す．評価は，(1) OT プロトコルとベンダの公開状況の調査，(2) 実機からの識別情報の取得と正規化，(3) CSAF 文書の収集，(4) 候補アドバイザリの抽出，(5) 製品エントリの対応付け，(6) 版条件の評価，(7) 判定レベルの決定，の順に行った．

実機情報は，識別応答が指す CPU，通信ユニット等のコンポーネント単位で管理する．公開情報との対応付けは，原則として CVE・製品条件単位で評価する．ただし，候補アドバイザリまたは製品対応付けの根拠を得られず，CVE・製品条件単位へ展開できない場合は，コンポーネント単位で未判定として記録する．

対応付けは，製品名の文字列類似度だけで脆弱性該当を決定せず，製品対応付けの根拠と版条件の評価を分離して行う．最後に両者を合成し，確定度に応じた判定レベルを付与する．

3.1 公開情報調査の対象

公開情報調査の基準日は 2026 年 8 月 19 日とした．プロトコルは，日本国内で利用される産業用コントローラとの関係，Ethernet 経由での利用，および公開資料から識別要求の有無を評価できることを基準に，Modbus/TCP，EtherNet/IP，FINS，S7comm，SLMP，CC-Link IE Field Network Basic の 6 種を選定した．識別属性を十分に取得できること自体は選定条件とせず，汎用的な識別要求を確認できない場合も方式の限界として残した．

脆弱性情報の公開状況は，三菱電機，KEYENCE，OMRON，Siemens，富士電機，Schneider Electric の 6 社を対象とした．国内 3 社は PLC 技術者を対象とする公開アンケートを参考に選び [9]，国内外の構成を考慮して 3 社を追加した．本選定は市場シェア上位 6 社を意味しない．

各社について，公式の集約ページ，HTML・PDF，CSAF Provider，RSS 等の通知手段，および産業用コントローラとその関連モジュールを対象とするアドバイザリを確認した．

3.2 機器情報の取得と正規化

対象 IP とプロトコルを事前に限定し，公開仕様または公開実装から確認できる状態変更を意図しない識別要求を送信した．主な候補は，Modbus/TCP の Read Device Identification [10]，EtherNet/IP の ListIdentity ／ Identity Object [11], [12]，FINS の Controller Data Read [13]，S7comm の SZL および I&M 情報 [14], SLMP の Read Type Name [15] である．CC-Link IE Field Network Basic には公開マニュアルが存在する [16] が，外部スキャナが型式・版情報を取得する汎用的な識別要求を確認できなかったため，実機識別には用いなかった．

応答の生値を保存し，空白，大文字小文字，全角半角および区切り文字を正規化した．ベンダ，シリーズ，モデル名，製品識別コード（型式，製品コード，ベンダ仕様上の注文番号等），ハードウェア版，ファームウェア版，アプリケーション版を別フィールドに保持し，CPU と通信ユニット等を別コンポーネントとして管理した．ベンダ識別子が数値で返される場合（例：EtherNet/IP の Vendor ID）は，仕様策定団体等が公開する公式対応表に当該値が登録されている場合に限り，ベンダ名へ変換した．

3.3 脆弱性情報の収集

CISA および製品ベンダが CSAF 2.0 [6] で配信するアドバイザリを，provider metadata および ROLIE フィードから収集した．文書ごとに取得元 URL，SHA-256，配信元が公開するダイジェスト，ETag および取得時刻を記録し，配信元のダイジェストと一致しない文書は保存せず取得失敗として計上した．対応付けはローカルに保存した同一コーパスに対してオフラインで実行するため，同一コーパスと同一規則からは同一の結果が得られる．情報源を CSAF に限定したのは，HTML・PDF からの情報抽出精度や，NVD ／ CPE とのスキーマおよび製品表現の差異を評価要因から分離し，CSAF 文書を入力とする対応付け可能性を決定的規則で検証するためである．

処理には，3.5 節に示す対応付け方式を本研究のために実装した処理系を用いた．正規化，版解釈，製品対応付けおよび判定の規則はそれぞれ版 1.0.0 へ固定し，出力へ規則版を記録した．判定は決定的な規則だけで行い，大規模言語モデルは使用していない．

3.4 判定レベル

対応付け結果の判定レベルの定義を表 1 に示す．対応付け結果は，`confirmed`，`probable`，`possible`，`not_affected` および `unknown` の 5 種類で表す．`confirmed`，`probable`，`possible` および `not_affected` は CVE・製品条件単位の判定である．`unknown` は候補を生成できないコンポーネン

© 2026 Information Processing Society of Japan

表 1: 対応付けの判定レベル

判定	定義
`confirmed`	製品固有キーが完全一致し，対応を確認できる版情報の全解釈で影響版条件を満たす
`probable`	製品対応または版情報の根拠が推定に留まるが，影響版条件を満たす
`possible`	シリーズ／ファミリ単位で一致する，または版条件の評価が保留となり，機種・版を一意に確定できない
`not_affected`	対象製品との関係を確認でき，明示的な否定情報が与えられるか，版数の有効な全解釈で影響版条件の範囲外となる
`unknown`	候補勧告または製品対応付けの根拠を得られず，CVE・製品条件単位の判定へ進めない

ト単位の結果，または文字列類似度以外の根拠を得られない候補に用い，CVE 単位の判定件数には含めない．脆弱性への該当可能性を示す判定レベルには，`confirmed` > `probable` > `possible` > `unknown` の順序を与える．製品対応付けおよび版情報の根拠が弱い場合，後述する規則により最終判定の上限を制限する．

3.5 対応付け方式

3.5.1 コンポーネントと識別情報

走査結果の組（IP アドレス，プロトコル，ポート）を対応付けの基本単位とし，これをコンポーネント c と呼ぶ．同一 IP アドレスであっても異なるプロトコルで応答した場合は別コンポーネントとして扱い，一方に対応付けた脆弱性を他方へ転記しない．これは，PLC の CPU と通信ユニットが同一 IP アドレスで異なるプロトコルに応答する構成が存在するためである．各コンポーネントには，識別応答が指す対象に基づき，CPU，通信ユニットまたは不明の種別 $\tau(c)$ を付与する．種別はプロトコルごとの既定値を出発点とし，型番が既知のパターンに一致する場合は型番による判定を優先する．

応答の生値には，Unicode NFKC 正規化，制御文字の除去，ハイフン類の ASCII ハイフンへの統一，連続空白の圧縮および比較用の大文字化を順に適用する．さらに，ベンダ固有規則として注文番号中の空白除去，正規表現による製品固有キーの認定，型番からのシリーズ／ファミリ導出を行う．生値と適用した変換列を保存し，元からの一致と正規化後の一致を区別する．

ベンダの決定は，(1) 応答に含まれるベンダ名，(2) プロトコルで定義されたベンダ識別子と，仕様策定団体等が公開する公式対応表との照合，(3) プロトコルがベンダ固有であることに由来する含意，の順に行う．いずれにも該当しない場合はベンダを推測せず未特定とする．

3.5.2 製品候補の解決と除外

コンポーネント c と勧告上の製品エントリ p の対応付けは，根拠 $e(c,p)$ を表 2 の階層で与える．根拠の強さは判定レベルの上限 $\Lambda_P(e)$ を定めるだけであり，スコアが閾値を超えたことのみを理由に脆弱性該当と判定することはない．同一勧告内に複数の製品エントリが一致した場合は，最も強い根拠で一致したエントリのみを採用する．これは，製品固有キーが完全一致しているにもかかわらず，同一文書中の別機種をシリーズ一致で重複して数えることを避けるためである．

次の 2 条件のいずれかを満たす候補は除外し，除外理由を結果に残す．第 1 に，双方のベンダが特定できており，かつ一致しない場合である．第 2 に，コンポーネント種別が矛盾する場合，すなわち $\tau(c)$ と勧告側製品の種別がいずれも既知で異なる場合である．後者は，装置本体に対してエンジニアリングソフトウェアの脆弱性を付与すること，および CPU の脆弱性を通信ユニットへ付与することを防ぐ．

3.5.3 版条件の評価

勧告が製品エントリに与える版条件 φ を，purl-vers 形式，不等号の列，自然言語表現（*prior to*，*and later* 等）および全版指定の各記法から解釈する．条件の一部しか解釈できない場合は，解釈できた部分だけで判定せず，条件全体を解釈不能として扱う．たとえば区切りなしで連結された二つの不等号について，一方のみを読むと影響範囲を誤って広く，あるいは狭く判定するためである．

機器側の版数は単一値ではなく，生値から成立する解釈の集合 $V(c)$ として扱う．ゼロ詰め表記が整数列と小数の両方に読める場合や，同一フィールドに複数の版数らしき値が存在する場合は，すべてを候補に含める．

版条件の評価は，真偽の 2 値ではなく次の 3 値とする．

$$\mathrm{eval}(V,\varphi) = \begin{cases} \mathsf{sat} & (\forall v \in V:\ v \models \varphi) \\ \mathsf{unsat} & (\forall v \in V:\ v \not\models \varphi) \\ \mathsf{ind} & (\text{上記以外}) \end{cases} \tag{1}$$

すなわち sat は影響版条件を満たすこと，unsat は満たさないこと，ind は判定を保留することを表す．

版数の有効な全解釈で結論が一致した場合にのみ確定し，解釈によって結論が分かれる場合は保留する．φ を解釈できない場合，および機器から版数を取得できない場合も保留とする．解釈不能を偽として扱わないのは，偽が「影響なし」と読まれ，該当の取りこぼしを生むためである．

個々の版数の比較は，トークン列の辞書式比較で行い，浮動小数点として扱わない．これにより 2.10 を 2.9 より新しい版として扱う．トークン数が異なる場合は不足分を 0 とみなす．

さらに，機器から得た版情報と勧告の版条件が同一の版体系に基づくことを確認できない場合は，数値上の比較が

© 2026 Information Processing Society of Japan

表 2: 製品対応付けの根拠と判定レベルの上限

根拠 e	例	上限 $\Lambda_P(e)$
製品固有キーの完全一致	型式，モデル番号，製品コード，SKU	`confirmed`
伏せ字型番への構造化一致	型番の可変部を*，[]，□等で伏せた表記	`probable`
シリーズ／ファミリ一致	「（シリーズ名） CPU family」等の総称	`possible`
文字列類似度	候補生成の補助のみ	`unknown`

可能であっても結果を ind とする．ここで版体系とは，版が表す対象と，版番号の付与・比較規則を指す．例えば，識別応答が通信ユニットの `Revision 1.2` を返し，勧告が CPU のファームウェア版 2.0 未満を影響範囲とする場合，1.2 と 2.0 は数値列として比較できても，対象と版の意味が異なるため比較しない．一方，1.0.0 と 1.00 のような差は版表記の問題であり，同一の版体系に基づくことと両表記の対応を確認できる場合に限り，正規化して比較する．ただし φ が全版指定の場合は版数によらず該当するため，この制約は適用しない．

3.5.4 判定の合成

3.4 節で定義した判定レベルに基づき，製品対応付けと版条件の評価を次のように合成する．まず CSAF の `product_status` を参照し，当該製品が `known_not_affected` に列挙される場合，および `fixed` に列挙され，かつその版条件について eval = sat となる場合は，他の根拠によらず `not_affected` とする．明示的な否定情報を，一般的な製品名の推定より優先するためである．

影響ありとして列挙された製品については，式 (1) の結果から基準レベルを

$$\Lambda_0 = \begin{cases} \texttt{confirmed} & (\text{eval} = \text{sat}) \\ \texttt{possible} & (\text{eval} = \text{ind}) \end{cases} \tag{2}$$

と定め，最終的な判定レベルを

$$\Lambda = \min\{\Lambda_0,\ \Lambda_P(e),\ \Lambda_V(c)\} \tag{3}$$

とする．ここで min は前述の全順序に関する最小元である．$\Lambda_P(e)$ は表 2 の上限，$\Lambda_V(c)$ は版情報の確度による上限であり，取得した版数の意味が勧告の版条件と対応することを確認できる場合は `confirmed`，対応が推定に留まる場合は `probable`，多義的または体系が異なる場合は `possible` とする．φ が全版指定の場合は版数が判定に影響しないため Λ_V を適用しない．eval = unsat の場合は `not_affected` とするが，文字列類似度のみで対応付けた候補については，別機種の版条件から影響なしを導くことになるため `unknown` に留める．どの上限が結果を律速したかは判定ごとに記録する．

3.5.5 重複整理と判定証跡

同一 CVE で勧告間に参照関係がある場合は，製品ベンダの勧告を canonical，調整機関の再公開を republication として統合する．対象製品・版条件が異なる場合は別判定として保持し，結果が分かれた場合は発行元を優先して差異を記録する．各判定には，生値，正規化，一致根拠，版条件の解釈，`product_status`，除外理由および規則版を保存する．

4. 公開情報調査の結果

4.1 プロトコル別の取得可能属性

表 3 に，公開資料から確認した識別経路と属性を示す．「M」は仕様上必須，「O」は任意または機種依存，「I」はプロトコル種別や ID からの推定，「V」はベンダ固有，「—」は標準的な取得手段なし，「?」は公開情報から確認できないことを表す．

5/6 プロトコルで，モデル名または製品コードに相当する識別経路を確認した．版相当の値は 4 プロトコルで確認したが，その意味がアドバイザリの版条件と一致するとは限らなかった．また，EtherNet/IP 等では応答が産業用コントローラ本体ではなく通信アダプターを表す場合があり，取得属性にコンポーネント情報を付与する必要がある．

4.2 ベンダ別の公開状況

表 4 に対象 6 社の調査結果を示す．「確認できず」は，2026 年 8 月 19 日時点で，当該情報または提供経路を一般公開情報から確認できなかったことを示し，その不存在を断定するものではない．

公式の集約ページを確認できたのは 4/6 社，ベンダ自身が配信する CSAF を確認できたのは 2/6 社であった．公式 RSS は 3/6 社で確認し，1 社は通知登録を提供していた．CSAF を提供しないベンダについても HTML・PDF，CISA および JVN に情報が存在する場合がある [27], [28] ため，「ベンダ自身の CSAF なし」と「公開脆弱性情報なし」は区別する必要がある．

自動対応付けには，識別応答，対象コンポーネント，型式・版の意味，候補勧告，および同粒度の製品・版条件がすべて必要である．次章では，実機評価により各条件の失敗箇所を確認する．

5. 実機評価

5.1 評価対象とコーパス

評価候補 4 ベンダのうち，公開情報だけから状態変更を

© 2026 Information Processing Society of Japan

表 3: プロトコル別の識別経路と取得可能属性

プロトコル	識別経路	ベンダ	モデル	製品コード	版・FW	シリアル	主な識別対象
Modbus/TCP	Read Device Identification	M*	O*	M*	M*†	V	応答する Modbus 機器
EtherNet/IP	ListIdentity ／ Identity Object	M	M	M	M†	M	装置または通信アダプター
FINS	Controller Data Read	I	O	—	O†	—	CPU または Ethernet Unit
S7comm	SZL ／ I&M 情報	I	O	O	O	O	CPU または指定モジュール
SLMP	Read Type Name	I	M	M	—	—	アクセス先モジュール
CC-Link IE Field Network Basic	汎用的な外部識別要求を確認できず	I ／?	?	?	?	?	リモート局

* Modbus の M は Read Device Identification を実装する機器内での必須性を示し，同機能自体が全 Modbus 機器で必須であることを意味しない．† Modbus の MajorMinorRevision，EtherNet/IP の Revision，FINS の Controller Version が，アドバイザリ上のファームウェア版と同じ体系とは限らない．

表 4: 脆弱性情報の公開状況（2026 年 8 月 19 日時点）

ベンダ	公式集約ページ	主な形式	ベンダ自身の CSAF	通知手段
三菱電機 [17], [18]	あり	HTML・PDF	確認できず	RSS
KEYENCE [19]	全社横断一覧は確認できず	個別 HTML	確認できず	確認できず
OMRON [20]	あり	HTML・PDF	確認できず	RSS
Siemens [21], [22]	あり	HTML・PDF・CSAF	あり	RSS
富士電機 [23], [24]	全社横断一覧は確認できず	製品更新情報, JVN・CISA による補完	確認できず	確認できず
Schneider Electric [25], [26]	あり	HTML・PDF・CSAF	あり	通知登録

意図しない識別要求を構成し，正解となる製品・版情報を確認できた 3 ベンダ 5 台を主評価対象とした．CPU と通信ユニット等を分離した評価単位は 7 コンポーネントである．残る 1 ベンダは，公開情報だけで再現可能な識別経路を確立できなかったため実機評価から除外したが，公開情報調査の対象には残した．なお，実機評価では機器名およびベンダ固有プロトコル名を匿名化し，Device A〜C，Protocol P1 ／ P2 として示す．匿名化の理由と適用範囲は 6.3 節に述べる．

公開脆弱性情報は，2026 年 8 月 19 日時点の調整機関による勧告 3,875 件と製品ベンダによる勧告 248 件，計 4,123 件を用いた．製品条件へ展開したエントリ数は 36,473 件である．同一機種の複数台による偏りを避けるため，以下の件数は 1 台あたりに換算した．

5.2 ケース別の対応付け結果

表 5 に機器・コンポーネント別の対応付け結果を示す．「候補勧告」は重複統合後の論理アドバイザリ数，「判定」は事前除外後に評価した CVE・製品条件数，「事前除外」はコンポーネント種別の矛盾により除外した潜在的な CVE・製品条件数である．一つの勧告が複数の判定を生成する場合と，判定を生成しない場合があるため，候補勧告数と判定数は一致しない．

Device A では，機器の製品識別コードと勧告の製品キーが空白正規化後に完全一致した．完全一致した 10 判定は，版条件により `confirmed` 5 件と `not_affected` 5 件に分かれ，製品固有キーと比較可能な版情報が揃えば確定判定が可能であることを示した．一方，シリーズ単位の候補は `possible` に制限された．

Device B の CPU では製品固有キーを取得できず，伏せ字型番またはシリーズ単位の一致に留まったため，`confirmed` には至らなかった．ただし，1 件は版数の全解釈が影響範囲外となり，`not_affected` を確定できた．通信ユニットでは，種別が整合する 4 判定を `possible` とし，CPU を対象とする別の 4 判定を種別矛盾により事前除外した．

Device C ではベンダと型番を特定できたが，使用した CSAF コーパスから候補勧告を生成できず，コンポーネント単位の `unknown` とした．これは脆弱性の不存在ではなく，用いた情報源から判定できないことを意味する．

5.3 判定根拠と確定を妨げる要因

事前除外を含まない全 70 判定のうち，`confirmed` 5 件と `not_affected` 43 件を確定し，22 件（`probable` 2 件，`possible` 20 件）は未確定であった．`unknown` はコンポーネント単位の結果であり，70 件には含めない．製品固有キーの完全一致では確定判定まで到達した一方，伏せ字型番とシリーズ／ファミリ一致では，該当側の上限がそれぞれ `probable`，`possible` となった．文字列類似度のみで判定した事例はなかった．未確定 22 件の要因を表 6 に示す．機器側では，ゼロ詰めや同一フィールド内の複数値により

© 2026 Information Processing Society of Japan

表 5: 機器・コンポーネント別の対応付け結果（1 台あたり）

コンポーネント	プロトコル	候補	判定	confirmed	probable	possible	not affected	種別矛盾で除外
Device A（CPU）	Protocol P1	60	56	5	0	9	42	0
Device B（CPU）	Protocol P2	5	10	0	2	7	1	0
Device B（通信ユニット）	EtherNet/IP	1	4	0	0	4	0	4
Device C（CPU）	EtherNet/IP	0	0	0	0	0	0	0

表 6: 確定的な脆弱性該当判定に至らなかった要因

層	要因	件数
機器側	版数表記が多義的	7
機器側	取得した版の体系が勧告と異なる	4
公開情報側	版条件が非定型で機械解釈できない	5
公開情報側	対象製品がシリーズ単位で記載される	4
公開情報側	型番が伏せ字で記載される	2
方式側	正規化・照合規則の不足に帰着	0
計	**機器側 11，公開情報側 11，方式側 0**	**22**

版数を一意に定められない事例と，値は一意でもプロトコル上の版情報と勧告上の版情報の体系が異なる事例があった．公開情報側では，`2.X|3.X` のようなワイルドカード列挙，注釈を含む条件，区切りなしで連結された複数の不等号，および機能設定を含む条件を確認した．条件の一部だけを解釈すると誤判定につながるため，規則で全体を解釈できない場合は確定しなかった．

方式側 0 件という結果は方式の完全性を意味しない．不足情報を推定で補わず，根拠が弱い結果を `probable`，`possible` または `unknown` に制限した設計の帰結である．

6. 考察

6.1 RQ への回答

RQ1：5/6 プロトコルでモデルまたは製品コードの識別経路を確認した一方，ベンダ自身による CSAF は 2/6 社でのみ確認できた．さらに，版の体系とコンポーネント単位が一致しなければ，両者が存在しても対応付けを確定できない．

RQ2：実機評価では，製品固有キーと，勧告と同じ体系で一意な版数の双方を取得できたケースで，5 件の脆弱性該当と 5 件の非該当を確定できた．製品固有キーを得られない場合は，伏せ字型番またはシリーズ単位の候補提示が上限となった．また，CPU と通信ユニットを分離することで，種別が矛盾する 4 件を除外できた．

RQ3：確定に至らない 22 件は，機器側 11 件と公開情報側 11 件に二分された．中心的な問題は，属性値の欠落だけではなく，版数の意味・一意性と，製品記述の粒度の不一致であった．

6.2 実務および標準化への示唆

機器側では，状態変更を伴わない識別要求を公開し，製品固有キー，ファームウェア版，版の種類および対象コンポーネントを区別して返すことが望ましい．資産管理側でも，モデル名と版数だけでなく，識別子の種類，版の意味，取得対象コンポーネントおよび取得根拠を保持する必要がある．

脆弱性情報側では，CSAF 等の機械可読形式を継続的に提供し，機器が返す型式・注文番号と対応する識別子，機械解釈可能な影響版条件，および影響コンポーネントを明記することが望ましい．本結果は対象市場全体の優劣を示すものではないが，本評価で観測した判定不能を減らすには，これらの公開と構造化が有効と考えられる．

6.3 記載方針と倫理上の配慮

本研究の記載は，公開情報調査と実機評価で方針を分けた．公開情報調査では再現性を優先し，対象ベンダ名およびプロトコル名を明記した．これらはいずれも一般に公開された資料に基づく記述であり，特定の機器の稼働状態を示すものではない．

一方，実機評価では，個別 CVE 自体は公開情報であるものの，製品・詳細版と組み合わせると現存機器の脆弱性状態を推定できるため，ベンダ名，製品名および詳細版を匿名化し，個別の CVE 識別子・勧告 ID は非掲載としたうえで，Device A〜C の集計結果のみを示した．ベンダ固有で名称から実機を推定できるプロトコルも Protocol P1 ／ P2 とし，複数ベンダが実装する EtherNet/IP のみ実名で記載した．

本研究で観測した判定不能の要因は，いずれも個別製品の欠陥ではなく，識別情報と公開脆弱性情報の記述粒度に関する構造的な課題である．したがって，匿名化によって本論文の主張と再現可能性が損なわれることはないと考えるが，匿名化した範囲については第三者による同一機器での追試ができない点を制約として明記する．

6.4 制限事項

本研究には，(1) 公開情報調査対象の 6 社・6 プロトコルが目的抽出で市場全体を代表せず，実機も 3 ベンダ 5 台・7 コンポーネントと小規模であること，(2) ベンダ CSAF の取得が 831 件中 248 件に留まり，HTML・PDF，JVN，NVD ／ CPE を照合に用いていないため，公開脆弱性情報全体の網羅性を評価していないこと，(3) 正解 CVE 集合による適合率・再現率と通信影響を評価していないこと，

© 2026 Information Processing Society of Japan

(4) 匿名化と個別 CVE の非掲載により，同一機器・同一結果を直接追試できないこと，という制約がある．したがって，判定件数は対象とコーパスに依存し，候補 0 件または `unknown` は脆弱性の不存在を意味しない．ただし，対応付け規則と判定証跡の形式により，他機器への同一手順の適用は可能である．

7. おわりに

本研究では，OT 機器の識別情報と公開脆弱性情報の対応付け可能性を，6 プロトコル・6 ベンダの公開情報調査と，3 ベンダ 5 台・7 コンポーネントの実機評価により検討した．公開情報調査では 6 プロトコル中 5 プロトコルで識別経路を確認し，ベンダ自身による CSAF は 2/6 社で確認した．実機評価では 5 件を `confirmed`，43 件を `not_affected` として確定した一方，22 件は機器側または公開情報側の制約により確定できなかった．

結果から，自動対応付けにはモデル名と版数の取得だけでなく，安定した製品固有キー，版の意味と一意性，対象コンポーネント，および機械解釈可能な影響版条件が必要であることが分かった．今後は，ベンダ CSAF コーパスの完全化，HTML・PDF 等を加えた情報源別比較，正解 CVE 集合による精度評価，対象機種の拡大，および通信影響の定量評価を行う．

参考文献

[1] National Institute of Standards and Technology: Guide to Operational Technology (OT) Security, Technical Report NIST SP 800-82 Rev. 3, National Institute of Standards and Technology (2023).

[2] Cybersecurity and Infrastructure Security Agency: Foundations for OT Cybersecurity: Asset Inventory Guidance for Owners and Operators, Guidance, Cybersecurity and Infrastructure Security Agency (2025).

[3] Samanis, E., Gardiner, J. and Rashid, A.: SoK: A Taxonomy for Contrasting Industrial Control Systems Asset Discovery Tools, *Proceedings of the 17th International Conference on Availability, Reliability and Security*, (online), DOI: 10.1145/3538969.3538979 (2022).

[4] Nmap Project: NSE Documentation, Nmap.org (online), available from ⟨https://nmap.org/nsedoc/scripts/⟩ (accessed 2026-08-19).

[5] U.S. Department of Energy: Safe Active Scanning for Energy Delivery Systems: Final Report, Technical report, U.S. Department of Energy (2017).

[6] OASIS Open: Common Security Advisory Framework (CSAF) Version 2.0, Oasis standard, OASIS Open (2022).

[7] Cybersecurity and Infrastructure Security Agency: CSAF Security Advisories Repository, GitHub (online), available from ⟨https://github.com/cisagov/CSAF⟩ (accessed 2026-08-19).

[8] Sanguino, L. A. B. and Uetz, R.: Software Vulnerability Analysis Using CPE and CVE (2017). arXiv:1705.05347.

[9] 岡　実：130 人の声が示す PLC の “現在地” 製造現場が抱える課題、期待を分析，MONOist（オンライン），入手先 ⟨https://monoist.itmedia.co.jp/mn/articles/2509/11/news005.html⟩（参照 2026-08-19）．

[10] Modbus Organization: MODBUS Application Protocol Specification, Specification V1.1b3, Modbus Organization (2012).

[11] ODVA: The CIP Networks Library, Volume 2: EtherNet/IP Adaptation of CIP, Specification v1.36, ODVA (2026).

[12] ODVA: The CIP Networks Library, Volume 1: Common Industrial Protocol (CIP), Specification v3.40, ODVA (2026).

[13] OMRON: *FINS Commands Reference Manual* (2001). Cat. No. W227-E1-2.

[14] Siemens: Get_IM_Data: Reading Identification and Maintenance Data (S7-1200, S7-1500), TIA Portal Documentation (online), available from ⟨https://docs.tia.siemens.cloud/r/en-us/v20/extended-instructions-s7-1200-s7-1500/diagnostics-s7-1200-s7-1500/get_im_data-reading-identification-and-maintenance-data-s7-1200-s7-1500⟩ (accessed 2026-08-19).

[15] Mitsubishi Electric: *SLMP Reference Manual*. Document No. SH-080956ENG.

[16] Mitsubishi Electric: *CC-Link IE Field Network Basic Reference Manual*. Document No. SH-081684ENG.

[17] 三菱電機：脆弱性情報一覧（PSIRT），三菱電機 PSIRT（オンライン），入手先 ⟨https://www.mitsubishielectric.com/psirt/vulnerability/index.html⟩（参照 2026-08-19）．

[18] 三菱電機：FA 製品の脆弱性情報，MITSUBISHI ELECTRIC Factory Automation（オンライン），入手先 ⟨https://www.mitsubishielectric.com/fa/about-us/security/vulnerability/index.html⟩（参照 2026-08-19）．

[19] キーエンス：製品セキュリティへの取り組み，キーエンス（オンライン），入手先 ⟨https://www.keyence.co.jp/support/product-security-commitment/⟩（参照 2026-08-19）．

[20] オムロン：制御機器の脆弱性情報，オムロン制御機器（オンライン），入手先 ⟨https://www.fa.omron.co.jp/product/security/vulnerability/⟩（参照 2026-08-19）．

[21] Siemens ProductCERT: Security Advisories, Siemens ProductCERT (online), available from ⟨https://www.siemens.com/cert/advisories⟩ (accessed 2026-08-19).

[22] Siemens ProductCERT: CSAF Provider Metadata, Siemens ProductCERT (online), available from ⟨https://cert-portal.siemens.com/productcert/csaf/provider-metadata.json⟩ (accessed 2026-08-19).

[23] 富士電機：PLC 製品情報，富士電機（オンライン），入手先 ⟨https://www.fujielectric.co.jp/products/drive_ctrl_equipment/plc/index.html⟩（参照 2026-08-19）．

[24] 富士電機：資料ダウンロード，富士電機（オンライン），入手先 ⟨https://felib.fujielectric.co.jp/⟩（参照 2026-08-19）．

[25] Schneider Electric: Security Notifications, Schneider Electric (online), available from ⟨https://www.se.com/ww/en/work/support/cybersecurity/security-notifications/⟩ (accessed 2026-08-19).

[26] Schneider Electric: Common Security Advisory Framework, White Paper CSAF2.0_Announcement, Schneider Electric (2022).

[27] Cybersecurity and Infrastructure Security Agency: ICS Advisories, CISA (online), available from ⟨https://www.cisa.gov/news-events/ics-advisories⟩ (accessed 2026-08-19).

[28] JPCERT/CC and IPA: JVN iPedia, JVN iPedia (online), available from ⟨https://jvndb.jvn.jp/⟩ (accessed 2026-08-19).

© 2026 Information Processing Society of Japan